WAS Experiment 04

Aim: Performing Reconnaissance & Information Gathering

Learning Objective: To demonstrate the process of reconnaissance and information gathering against an authorized target and understand how publicly available information, DNS records, domain information, technologies, and network services can be collected during the initial phase of a security assessment.

Learning Objectives:

After completing this experiment, students will be able to:

- Understand the concept of reconnaissance.
- Explain the importance of information gathering in cybersecurity.
- Differentiate between passive and active reconnaissance.
- Collect basic information about a target domain.
- Perform DNS information gathering.
- Identify IP addresses associated with a domain.
- Identify technologies used by a web application.
- Identify open ports and running services in an authorized environment.
- Analyze the information collected during reconnaissance.
- Understand the importance of performing reconnaissance only against authorized targets.

Tools: Kali Linux, Terminal, Web Browser and an authorized target/domain or local laboratory environment.

Theory:

Introduction

Reconnaissance is the initial phase of a cybersecurity assessment in which information about a target is collected before detailed security testing is performed.

The information collected during reconnaissance can help a security professional understand the target's:

- Domain names
- IP addresses
- DNS records
- Network services
- Open ports
- Web technologies
- Operating system information
- Publicly available information

Reconnaissance helps security testers understand the attack surface of a target and plan subsequent security assessments.

Types of Reconnaissance

1. Passive Reconnaissance

Passive reconnaissance involves collecting information without directly interacting with the target's systems.

Examples include:

- Public search engines
- Public DNS information
- WHOIS information
- Public websites
- Publicly available documents
- Search engine results

The objective is to collect information while minimizing direct interaction with the target.

2. Active Reconnaissance

Active reconnaissance involves directly interacting with the target system to collect information.
Examples include:

- Port scanning
- Service enumeration
- Technology identification
- Direct DNS queries
- Network discovery

Active reconnaissance can generate traffic that is visible to the target and therefore should only be performed when explicitly authorized.

Information Collected During Reconnaissance

1. Domain Information

Domain information may include:

- Domain name
- Registrar
- Registration information
- Name servers
- Domain status

The whois utility can be used to obtain publicly available domain registration information.

2. DNS Information

DNS translates domain names into IP addresses and provides other records associated with a domain.
Common DNS record types include:

- A — IPv4 address
- AAAA — IPv6 address
- MX — Mail exchange server
- NS — Name server
- TXT — Text information
- CNAME — Canonical name

3. IP Address Information

Identifying the IP address associated with a domain helps determine the network endpoint associated with the target.
Tools such as dig, host, and nslookup can be used to obtain DNS information.

4. Technology Information

Technology fingerprinting can help identify technologies used by a web application.
For example:

- Web server
- Programming language
- JavaScript frameworks
- Content Management System
- Web application technologies

The whatweb tool available in Kali Linux can be used for technology identification.

5. Port and Service Information
Network services communicate through ports.
Port scanning can help identify:

- Open ports
- Running services
- Service versions

Nmap is commonly used for authorized network discovery and service enumeration.

Procedure:

Step 1: Start Kali Linux

Start Kali Linux and open the Terminal.

Expected Output:

Kali Linux starts successfully and the terminal is available.

Step 2: Identify the Target

Select a domain, IP address, or laboratory system for which you have permission to perform reconnaissance.

For example:

Target: <authorized-domain>

For a classroom laboratory, a local machine or intentionally vulnerable application can be used.

Expected Output:

The authorized target is identified.

Step 3: Perform WHOIS Information Gathering

Execute:

whois <authorized-domain>

Review the information returned by the command.

Expected Output:

Available domain registration and name-server information is displayed.

Step 4: Perform DNS Enumeration Using nslookup

Execute:

nslookup <authorized-domain>

Observe the returned IP address and DNS server information.

Expected Output:

The DNS resolver returns information associated with the domain.

Step 5: Perform DNS Enumeration Using dig

Execute:

dig <authorized-domain>

To query a specific record type, for example:

dig <authorized-domain> A

Expected Output:

The DNS response displays the requested DNS information.

Step 6: Identify Name Servers

Execute:

dig <authorized-domain> NS

The command retrieves the domain's name-server records.

Expected Output:

The authoritative name servers associated with the domain are displayed.

Step 7: Identify Mail Servers

Execute:

dig <authorized-domain> MX

Expected Output:

The available mail-exchange records associated with the domain are displayed.

Step 8: Use the host Command

Execute:

host <authorized-domain>

Observe the IP address information returned.

Expected Output:

The command displays DNS information associated with the target.

Step 9: Perform Web Technology Identification

Use WhatWeb against the authorized web application:

whatweb http://<authorized-domain>

Expected Output:

WhatWeb displays information about technologies detected on the web application.

The information may include:

- Web server
- Framework
- JavaScript libraries
- CMS
- Other detected technologies

Step 10: Perform Port Scanning

Use Nmap against the authorized target:

nmap <authorized-ip>

For service identification:

nmap -sV <authorized-ip>

Expected Output:

Nmap displays the discovered ports and, where detectable, the services and versions running on those ports.

Step 11: Analyze the Collected Information

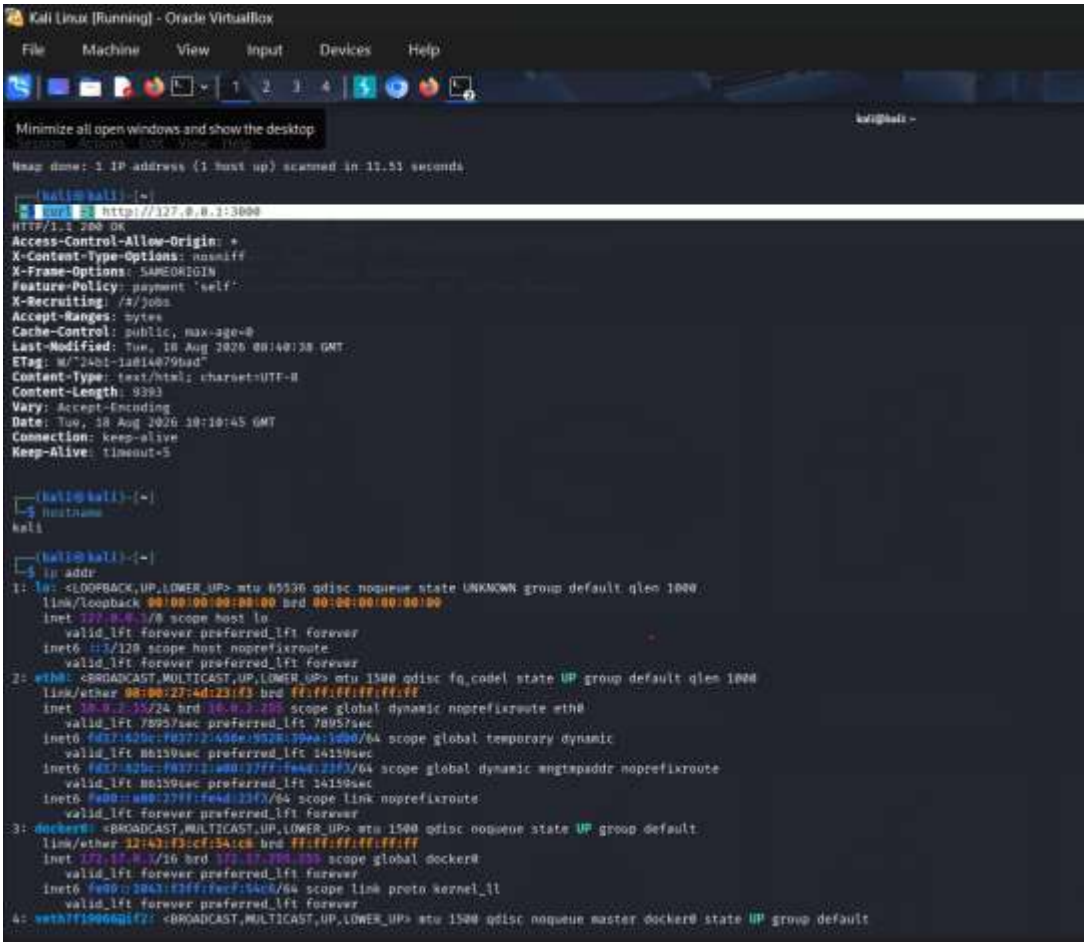
Organize the information collected during the reconnaissance process.

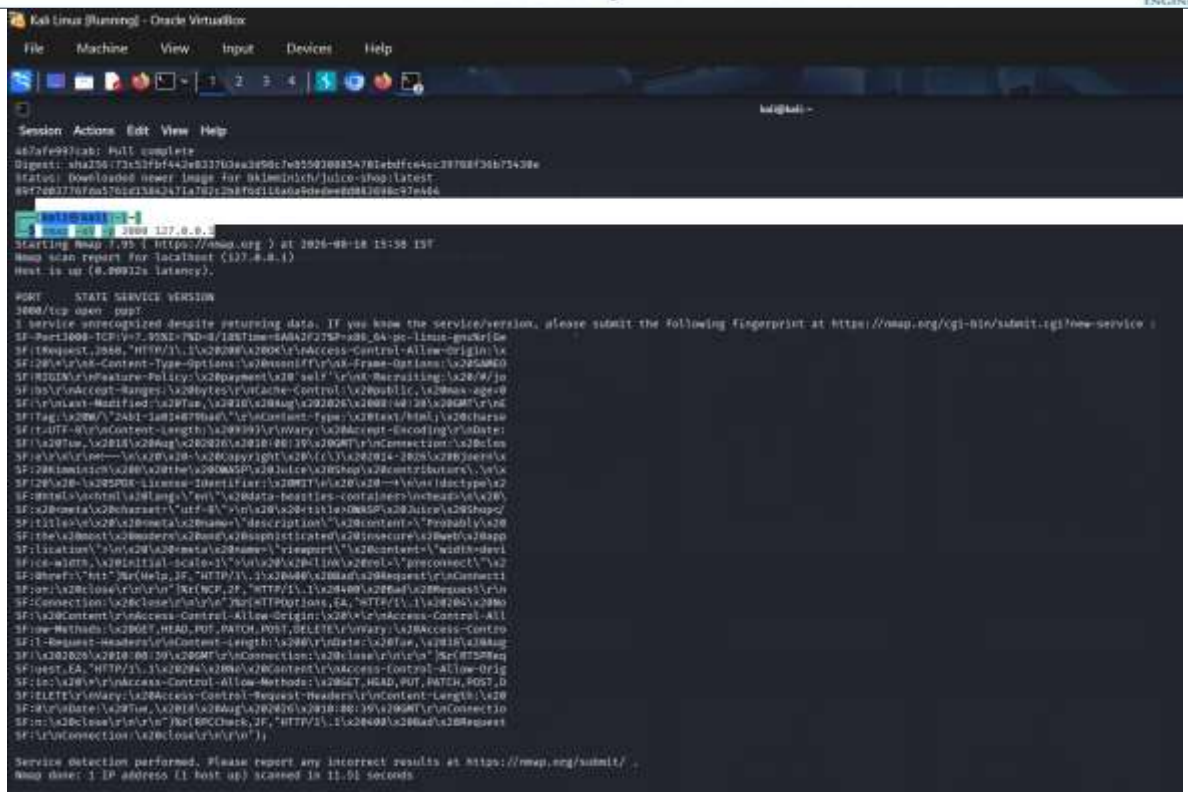
Expected Output:

A basic profile of the authorized target's infrastructure and web environment is created.

Outputs:

```
┌──(kali㉿kali)-[~]
└─$ curl -s http://127.0.0.1:3000 | grep -Eo 'src="[^"]+|href="[^"]+' | head -20
href="https://fonts.googleapis.com
href="https://fonts.gstatic.com
href="assets/public/favicon_js.ico
href="styles.css
href="styles.css
src="polyfills.js
src="scripts.js
src="main.js
```






```
┌──(kali㉿kali)-[~]
└─$ curl -s http://127.0.0.1:3000/main.js | grep -Eo '/rest/[A-Za-z0-9_./?-]+' | sort -u | head -20
/rest/2fa/disable
/rest/2fa/setup
/rest/2fa/status
/rest/2fa/verify
/rest/admin
/rest/basket/
/rest/captcha
/rest/chat
/rest/continue-code
/rest/continue-code/apply/
/rest/continue-code-findIt
/rest/continue-code-findIt/apply/
/rest/continue-code-fixIt
/rest/continue-code-fixIt/apply/
/rest/country-mapping
/rest/deluxe-membership
/rest/image-captcha/
/rest/languages
/rest/memories
/rest/order-history

┌──(kali㉿kali)-[~]
└─$ curl -s http://127.0.0.1:3000/main.js | grep -Eo '/rest/[A-Za-z0-9_./?-]+' | sort -u | wc -l
34
```

Observation:

The following observations are made:

1. Domain information can be obtained using WHOIS.
2. DNS utilities can identify IP addresses and DNS records.
3. Different DNS record types provide different types of information.
4. WhatWeb can identify technologies used by a web application.
5. Nmap can identify accessible network ports and services.

6. The collected information helps in understanding the target's attack surface.
7. Passive reconnaissance generally involves less direct interaction than active reconnaissance.
8. Active reconnaissance should only be performed against systems for which authorization has been obtained.

Result and Discussion:

The experiment successfully demonstrated the process of reconnaissance and information gathering using Kali Linux tools.

Domain and DNS information was collected using whois, nslookup, dig, and host. Web technology information was obtained using WhatWeb, while Nmap was used to identify open ports and services on the authorized target.

The collected information provides a basic understanding of the target's infrastructure and attack surface. Reconnaissance is therefore an important initial stage of a cybersecurity assessment because it allows security professionals to identify relevant systems and services before conducting further authorized security testing.

Conclusion:

This experiment demonstrated the practical process of performing reconnaissance and information gathering using Kali Linux. Different tools were used to collect domain, DNS, IP address, web technology, port, and service information.

The experiment showed the difference between passive and active reconnaissance and demonstrated how the collected information can be organized to understand a target's attack surface.

Reconnaissance and scanning must always be performed within the scope of an authorized security assessment.

Viva Questions:

1. What is reconnaissance in cybersecurity?
2. What is the difference between passive and active reconnaissance?
3. What is the purpose of the whois command?

For Faculty Use:

Correction Parameters	Formative Assessment [40%]	Timely completion of Practical [40%]	Attendance / Learning Attitude [20%]	
Marks Obtained				